

GoPhish

Procedimiento técnico Phishing simulado

Concienciación ENS · Departamento IT

Versión	v1.0
Clasificación	Confidencial - Uso interno
Área responsable	Departamento IT
Enfoque	Revisión humana obligatoria
Alcance	Simulación controlada y formativa

ENS

OPEN SOURCE

NEXTLETTER

REVISADO

Índice de contenidos

Uso del documento

Este manual está pensado para implantar GoPhish de forma controlada, documentada y con revisión humana. No sustituye a la validación de Dirección, Legal/RRHH o Legitec en el marco ENS.

- 01 Introducción y contexto ENS
- 02 Objetivos del programa
- 03 Arquitectura segura
- 04 Requisitos previos
- 05 Instalación desde web oficial
- 06 Configuración inicial segura
- 07 Firewall y aislamiento
- 08 Ejecución y primer acceso
- 09 Funcionamiento de GoPhish
- 10 Fase piloto
- 11 Campañas simuladas
- 12 Métricas y reporting
- 13 Evidencias ENS
- 14 Integración con NextLetter
- 15 Gobierno, revisión humana y límites
- 16 Checklist final

01

Introducción y contexto ENS

Programa interno de concienciación en seguridad

Dentro del marco de la certificación ENS, LOGNEXT necesita reforzar la concienciación en seguridad a nivel organizativo. Este procedimiento define una implantación interna de phishing simulado mediante GoPhish, con enfoque formativo, trazable y revisado por el equipo IT.

El objetivo no es sancionar ni exponer a usuarios, sino medir el nivel de madurez, detectar hábitos de riesgo y generar acciones correctivas documentadas.

Principio clave

Automatización sí; envío automático no. Toda campaña, informe o comunicación debe pasar por revisión humana antes de publicarse o enviarse.

02

Objetivos del programa

Qué buscamos conseguir

- Evaluar el nivel de concienciación de los usuarios frente a correos fraudulentos.
- Detectar patrones de riesgo: aperturas, clics e interacciones con formularios simulados.
- Generar métricas objetivas para informes internos y evidencias ENS.
- Reducir dependencia de servicios externos sin perder control ni trazabilidad.
- Integrar los aprendizajes en la newsletter mensual NextLetter.
- Crear un ciclo de mejora continua: simular, medir, formar y volver a medir.

Dato importante

Los resultados públicos deben presentarse agregados. Los resultados individuales solo deben usarse internamente, con acceso limitado y finalidad formativa.

03

Arquitectura segura

Diseño recomendado para LOGNEXT

Componente	Recomendación	Motivo
VM	Ubuntu Server en VMware o Azure	Aislamiento, control y reversibilidad
RAM	2 GB	Suficiente para campañas de ~200 usuarios
CPU	1-2 vCPU	GoPhish es ligero
Disco	20 GB	Sistema, logs y evidencias
Red	NAT o red controlada	Evita exposición innecesaria a la red corporativa
Firewall	UFW activo	Limita el panel admin y reduce superficie de ataque
Panel admin	Solo IP de administración	Evita accesos no autorizados
Servidor phishing	No exponer hasta fase controlada	Primero validar piloto interno

Recomendación senior

Empieza en NAT y solo con acceso administrativo restringido. No publiques puertos de campañas hasta tener dominio, SMTP, landing y aprobación formal.

04

Requisitos previos

Antes de instalar

- VM Ubuntu Server preparada y actualizada.
- Acceso con usuario sudo.
- IP de administración desde la que se accederá al panel.
- Descarga manual del ZIP desde la web oficial: <https://getgophish.com>.
- Aprobación interna del piloto por parte de IT/Dirección.
- Compromiso de no usar credenciales reales ni integraciones con Active Directory.

Fuente oficial

Para evitar descargas no controladas, se recomienda entrar manualmente en <https://getgophish.com> y usar el botón Download. Desde ahí se accede al canal oficial de descarga del proyecto.

05

Instalación desde web oficial

Comandos para Ubuntu Server

Primero se prepara el sistema base y se crea el directorio donde quedará instalado GoPhish.

```
bash - preparación del sistema

sudo apt update && sudo apt upgrade -y
sudo apt install unzip curl wget ufw -y

sudo mkdir -p /opt/gophish
sudo chown $USER:$USER /opt/gophish
cd /opt/gophish
```

Descarga el archivo ZIP desde la web oficial en tu equipo o directamente desde la VM usando navegador/terminal según política interna:

```
descarga manual desde web oficial

# Fuente oficial recomendada:
# https://getgophish.com
#
# Descargar el archivo Linux 64-bit:
# gophish-vX.X.X-linux-64bit.zip
```

Si lo descargas en tu PC, súbelo a la VM. Ejemplo desde Windows PowerShell o terminal:

```
subida del ZIP a la VM

scp gophish-vX.X.X-linux-64bit.zip usuario@IP_VM:/opt/gophish/
```

Descomprime el archivo y aplica permisos de ejecución:

```
bash - descompresión

cd /opt/gophish
unzip gophish-vX.X.X-linux-64bit.zip
chmod +x gophish
ls -la
```

06

Configuración inicial segura

config.json

Antes de arrancar GoPhish, se revisa el archivo de configuración para limitar exposición.

```
editar configuración

cd /opt/gophish
nano config.json
```

Configuración recomendada en fase inicial: panel admin accesible desde la VM/red controlada y servidor de phishing sin exposición externa.

config.json - fase inicial

```
"admin_server": {
  "listen_url": "0.0.0.0:3333",
  "use_tls": true,
  "cert_path": "gophish_admin.crt",
  "key_path": "gophish_admin.key",
  "trusted_origins": []
},

"phish_server": {
  "listen_url": "127.0.0.1:8080",
  "use_tls": false,
  "cert_path": "example.crt",
  "key_path": "example.key"
}
```

Motivo

El servidor de phishing queda en 127.0.0.1 para evitar que quede expuesto antes de tener preparada la campaña, el dominio y la aprobación interna.

07

Firewall y aislamiento

UFW con acceso restringido

El panel de administración no debe estar abierto a toda la red. Se permite únicamente la IP del administrador.

```
bash - firewall UFW
sudo ufw default deny incoming
sudo ufw default allow outgoing

# Sustituir TU_IP_ADMIN por la IP desde la que administrarás GoPhish
sudo ufw allow from TU_IP_ADMIN to any port 3333 proto tcp

sudo ufw enable
sudo ufw status verbose
```

No abrir todavía

No abras los puertos 80/443/8080 para campañas reales hasta que hagamos el piloto, el dominio y la configuración SMTP.

08

Ejecución y primer acceso

Arranque controlado

```
bash - primer arranque
cd /opt/gophish
sudo ./gophish
```

En el primer arranque, GoPhish mostrará en consola la contraseña temporal del usuario admin. Guárdala de forma segura, entra al panel y cámbiala inmediatamente.

```
acceso al panel
https://IP_VM:3333

Usuario: admin
Contraseña: la que aparezca en la consola
```

Acción obligatoria

Cambiar la contraseña del usuario admin en el primer acceso. No crear campañas reales en esta fase.

09

Funcionamiento de GoPhish

Qué permite hacer

GoPhish funciona como una plataforma de simulación. Permite construir escenarios controlados y medir eventos de usuario sin ejecutar acciones maliciosas reales.

Módulo	Uso
Campaigns	Crear y programar campañas simuladas
Users & Groups	Cargar usuarios objetivo por grupos
Email Templates	Crear plantillas de correo simuladas
Landing Pages	Crear páginas formativas o simuladas
Sending Profiles	Configurar el perfil de envío SMTP
Results	Visualizar métricas y exportar resultados

Evento	Descripción	Uso recomendado
Open	El usuario abre el correo	Métrica orientativa, puede depender del cliente de correo
Click	El usuario hace clic en el enlace	Indicador principal de exposición
Submit	El usuario interactúa con formulario	Indicador crítico; no usar credenciales reales
Report	El usuario reporta el correo	Indicador positivo de concienciación

10

Fase piloto

Antes de tocar usuarios reales

- Crear una campaña solo para IT.
- Validar que el correo llega correctamente.
- Validar que el enlace registra clics.
- Validar que la landing muestra mensaje formativo.
- Validar exportación de resultados.
- Documentar capturas y conclusiones del piloto.

Criterio de paso a producción

No se debe pasar a usuarios finales hasta que IT valide entrega, métricas, landing, logs, privacidad y revisión humana.

11

Campañas simuladas

Diseño responsable

Cada campaña debe estar diseñada con una finalidad formativa concreta. No se trata de engañar por engañar, sino de entrenar comportamientos seguros.

Nivel	Tipo de campaña	Objetivo
1	Correo genérico de seguridad	Medir línea base inicial
2	Aviso corporativo creíble	Entrenar revisión de remitente y URL
3	Campaña temática M365	Entrenar señales de suplantación
4	Campaña avanzada controlada	Validar madurez tras formación

Ejemplo de estructura segura de landing formativa:

landing formativa

Título: Esto era una simulación de seguridad

Mensaje:

Has hecho clic en un enlace de una campaña interna de concienciación.
No se ha producido ningún incidente real.

Puntos a revisar:

- ¿El remitente era el habitual?
- ¿La URL coincidía con el dominio oficial?
- ¿El mensaje transmitía urgencia injustificada?
- ¿Pedía introducir credenciales?

Acción recomendada:

Ante la duda, reporta el correo al equipo IT.

Límite importante

No clones pantallas de login reales ni captures contraseñas reales en la primera fase. Para ENS, lo importante es la métrica y la formación, no recolectar secretos.

12

Métricas y reporting

Qué medimos

KPI	Descripción	Objetivo inicial	Objetivo maduro
Tasa de apertura	Usuarios que abren el correo	Medición informativa	Tendencia
Tasa de clic	Usuarios que hacen clic	< 25-30%	< 10%
Tasa de interacción	Usuarios que interactúan con formulario	< 10-15%	< 5%
Tasa de reporte	Usuarios que reportan el correo	> 5%	> 20%
Reincidencia	Usuarios que caen varias veces	Reducir	Seguimiento formativo

Los informes ejecutivos deben mostrar datos agregados por campaña, periodo y, si procede, área/departamento. Evitar nombres individuales en comunicaciones generales.

13

Evidencias ENS

Documentación a conservar

- Procedimiento aprobado de phishing simulado.
- Autorización de Dirección o responsable correspondiente.
- Alcance de la campaña: usuarios, fecha, objetivo y escenario.
- Plantilla de correo usada y landing asociada.
- Resultados agregados y evolución frente a campañas anteriores.
- Acciones correctivas: NextLetter, píldoras formativas o recordatorios.
- Acta o informe final de la campaña.
- Control de revisión humana previa al envío.

Carpeta recomendada
Evidencias_ENS/Concienciacion/AAAA/MM_Campaña_XX con procedimiento, capturas, exportaciones y resumen ejecutivo.

14

Integración con NextLetter

Cerrar el ciclo de aprendizaje

NextLetter será el canal mensual para transformar los datos en aprendizaje. La newsletter no debe señalar a personas; debe explicar tendencias, lecciones y retos.

Sección NextLetter	Fuente GoPhish	Ejemplo
Resultados del mes	KPIs agregados	El 88% evitó hacer clic en la simulación
Caso real	Tema de campaña	Cómo reconocer urgencias falsas
Consejo del mes	Error más común	Revisar dominio antes de iniciar sesión
Reto	Objetivo medible	Reducir clics por debajo del 10%
Enlaces útiles	INCIBE/CCN-CERT/Microsoft	Guías y vídeos cortos

Mensaje tipo
En la última simulación, la mayoría de usuarios identificó correctamente el intento. Nuestro objetivo del próximo mes es mejorar la tasa de reporte al equipo IT.

15

Gobierno, revisión humana y límites

Reglas de operación

Para que el proyecto sea defendible ante auditoría y aceptable internamente, debe existir un modelo claro de gobierno.

Control	Responsable	Evidencia
Diseño de campaña	IT	Plantilla y objetivo
Validación legal/comunicación	Dirección/RRHH/Legitec si aplica	Aprobación previa
Ejecución técnica	IT	Registro de campaña
Revisión de resultados	IT	Informe agregado
Comunicación formativa	IT/Comunicación	NextLetter revisada
Custodia de evidencias	IT	Repositorio/SharePoint

Política de no exposición

Nunca publicar rankings, nombres o capturas que identifiquen a usuarios que hayan caído. La finalidad es formativa y de mejora continua.

16

Checklist final

Antes de la primera campaña real

- VM aislada creada.
- GoPhish instalado desde web oficial.
- Panel admin protegido por firewall.
- Contraseña admin cambiada.
- Servidor phishing no expuesto en fase inicial.
- Piloto interno con IT ejecutado.
- Dominio y SMTP revisados.
- Campaña validada por revisión humana.
- Dirección/RRHH informados según proceda.
- Plantilla y landing revisadas.
- Informe ENS preparado.
- NextLetter preparada con datos agregados.

ANX**Anexo técnico**

Comandos resumidos

resumen de instalación segura

1. Preparar sistema

```
sudo apt update && sudo apt upgrade -y
sudo apt install unzip curl wget ufw -y
```

2. Crear directorio

```
sudo mkdir -p /opt/gophish
sudo chown $USER:$USER /opt/gophish
cd /opt/gophish
```

3. Descargar desde web oficial

```
# Abrir https://getgophish.com y descargar gophish-vX.X.X-linux-64bit.zip
```

4. Descomprimir

```
unzip gophish-vX.X.X-linux-64bit.zip
chmod +x gophish
```

5. Editar configuración

```
nano config.json
```

6. Configurar firewall

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow from TU_IP_ADMIN to any port 3333 proto tcp
sudo ufw enable
sudo ufw status verbose
```

7. Arrancar

```
cd /opt/gophish
sudo ./gophish
```

8. Acceso

```
# https://IP_VM:3333
# Usuario: admin
# Cambiar contraseña inmediatamente
```